

NIRIKSHAK (■■■■■■■■■■) & PRAHARAK (■■■■■■■■■■)

Dual-Twin Cyber Defense Framework: Contextual Insider Risk & Perimeter Ingress Hardening

Author: Kanishk Singh & Team	Stack: FastAPI + PostgreSQL 16 + Next.js + Isolation Forest	Verification: 100% Automated (25/25 Tests Passing)
Architecture: 4-Tier Zero-Trust Platform	Security Baseline: NIST FIPS 204 & MITRE ATT&CK;	Classification: 100% Synthetic Telemetry

1. Executive Summary & Foundational Axioms

Modern enterprise and defense environments face an asymmetric vulnerability: traditional perimeter defenses assume that once an entity is authenticated, it is implicitly trusted. Meanwhile, legacy SIEM solutions overwhelm SOC analysts with black-box alert fatigue. **NIRIKSHAK** and **PRAHARAK** operate as complementary dual-twins sharing a unified correlation core to provide complete 360-degree situational awareness without automated disciplinary punishment.

FOUNDATIONAL AXIOM I (The NIRIKSHAK Rule): <i>Unusual Activity ≠ Confirmed Malicious Activity</i> <i>Anomalous telemetry must never trigger autonomous disciplinary accusation. NIRIKSHAK serves strictly as an explainable Decision Support System, providing quantified mathematical attribution to human security analysts.</i>	FOUNDATIONAL AXIOM II (The PRAHARAK Rule): <i>Zero-Trust Cryptographic Deserialization</i> <i>No external signal, telemetry stream, or remote dispatch command is permitted to execute or deserialize without cryptographic anti-spoofing verification, timestamp freshness check, and sliding token-bucket circuit breaking.</i>
---	--

2. Dual-Twin Operational Philosophy & Comparison Matrix

The system separates security telemetry into two complementary analytical engines coupled by a temporal sliding-window correlation nexus:

DIMENSION	NIRIKSHAK (THE INSIDER TWIN)	PRAHARAK (THE OUTSIDER TWIN)
Primary Domain	Internal Identity, Device Trust & Data Access	Perimeter Ingress, Gateway APIs & Remote Dispatches
Core Question	<i>'Does this authenticated employee's access make contextual sense?'</i>	<i>'Does this external connection have any right to exist, and is it authentic?'</i>
Threat Vectors	Off-hours access, cross-department data reads, bulk exfiltration, stolen credentials	Forged signatures, command replay, reconnaissance scans, DDoS floods, spoofed UAV commands
Detection Logic	6-Factor Deterministic Scoring + Unsupervised Isolation Forest (6D Feature Vector)	Zero-Trust Crypto (Ed25519/HMAC/PQC) + Sliding Token-Bucket + MITRE ATT&CK; Recon
Response Posture	Decision support case dossier for mandatory human analyst triage	Proportional automated containment (15m Quarantine) + Cross-Domain Alert

3. NIRIKSHAK: 7-Layer Contextual Insider Risk Engine

Every internal access event traverses seven rigorous architectural layers:

1. Identity Confidence	Evaluates MFA verification freshness, session validity, and credential anomalies.
2. Device & Env Trust	Checks hardware enrollment in corporate inventory, trust score (0-100), and unmanaged endpoints.
3. Data Sensitivity	Multiplies risk based on classification tier (PUBLIC: 0, INTERNAL: 25, SENSITIVE: 60, CRITICAL: 100).
4. Behavioral Context	Compares against user and role baselines (typical working hours, department ownership, data volume Z-score).
5. Event Correlation	Tracks temporal sliding windows across sessions to detect lateral movement and multi-stage kill chains.
6. Explainable Scoring	Combines deterministic policy with ML anomaly indicators into an attributable 0-100 score.

7. Human Review	Generates security cases requiring audited human adjudication with mandatory justification.
-----------------	---

Deterministic Mathematical Formulation:

Final Risk Score = $w_1 \cdot I + w_2 \cdot D + w_3 \cdot S + w_4 \cdot B + w_5 \cdot A + w_6 \cdot C$
Configured Policy Weights: Identity $w_I = 0.20$, Device $w_D = 0.20$, Sensitivity $w_S = 0.20$, Behavior $w_B = 0.20$, ML Anomaly $w_A = 0.10$, Correlation $w_C = 0.10$.

Unsupervised Machine Learning Engine (Isolation Forest):

NIRIKSHAK implements an unsupervised **Isolation Forest** model trained on historical telemetry. It extracts a **6-dimensional feature vector**: [hours_offset, volume_zscore, device_familiarity, action_severity, sensitivity_tier, temporal_frequency]. The raw decision function is normalized into an additive 0-100 anomaly subscore. As mandated by operational rules, ML contributes strictly as one factor ($w_A = 0.10$) and never convicts independently.

4. PRAHARAK: Perimeter Threat & Outsider Risk Architecture

PRAHARAK inspects all external ingress telemetry, edge requests, and remote commands across five specialized sub-engines:

SUB-ENGINE	ALGORITHM / SPECIFICATION	OPERATIONAL EFFECT
Zero-Trust Crypto	HMAC-SHA256, Ed25519, NIST FIPS 204 ML-DSA (Dilithium-3 Post-Quantum)	Rejects tampered, forged, or replayed commands (freshness window: ≤ 120s) before deserialization.
Circuit Breaker	Sliding Token-Bucket (Fast: 10s burst > 15 req; Slow: 60s sustained > 60 req)	Transitions CLOSED → HALF-OPEN → OPEN. Automatically enforces 15-minute IP quarantine.
MITRE ATT&CK; Recon	Mapped tactics: T1595 (Scan), T1110 (Brute), T1190 (Exploit), T1071 (C2)	Detects endpoint enumeration, fuzzing payloads, and command-and-control beaconing patterns.
Origin & Locality	BGP Autonomous System (ASN) reputation, VPN egress, unapproved subnets	Identifies suspicious hosting providers, dark subnets, and non-defense network ranges.
Deterministic Formula	Risk = 0.20 S_Origin + 0.30 S_Integrity + 0.20 S_Recon + 0.15 S_Velocity + 0.15 S_Intel	Quantified 0-100 risk score producing dispositions: ALLOWED, CHALLENGED, THROTTLED, BLOCKED.

5. The Nexus: Cross-Domain Correlation Engine

The true core differentiator is the **Cross-Domain Correlation Engine (The Nexus)**. In sophisticated advanced persistent threats, an external attack is almost always coordinated with internal credential misuse.

THE CROSS-DOMAIN CORRELATION MECHANISM:

1. PRAHARAK intercepts external reconnaissance probes or brute-force attempts from an IP (e.g. 198.51.100.77) targeting /api/v1/auth.

2. Within the shared **30-minute sliding window**, NIRIKSHAK registers anomalous off-hours access or bulk exfiltration by an internal credential (USER-004).

3. The Nexus Engine performs cross-domain graph correlation: it links the external origin IP, compromised credential, and target repository.

4. **Unified Escalation:** The system generates a unified **CrossDomainIncident** with an amplified risk score (≥ 85.0 - CRITICAL), trips the circuit breaker to quarantine the external IP, elevates the internal case to Critical Priority, and fires a high-visibility incident alert in the SOC dashboard.

6. Database Architecture & Cryptographic Audit Trails

All state is persisted in **PostgreSQL 16** using SQLAlchemy Async ORM with UUIDv7 primary keys. Data integrity is guaranteed via append-only cryptographic hash chaining:

TABLE / ENTITY	PURPOSE & KEY ATTRIBUTES	INTEGRITY & RELATIONSHIPS
users	Synthetic user identities, departments (Engineering, Operations, Finance), roles (USER, ANALYST, ADMIN).	Foreign keys to events and cases.
devices	Enrolled corporate hardware, MAC/UUID, registration flag, trust level (TRUSTED, MONITORED, REVOKED).	Linked to access telemetry.

resources	Synthetic operational repositories (A, B, C, D) with classification tiers (LOW to CRITICAL).	Enforces departmental boundary checks.
access_events	Raw internal telemetry: timestamp, action, volume, MFA flag, total risk score, risk level.	Cascade relations to risk_factors.
risk_factors	Normalized subscores, weights, and human-readable explanation strings per evaluated event.	Enables complete mathematical explainability.
security_cases	Case management dossiers for events ≥ 61.0. Tracks status (OPEN, DISMISSED, ESCALATED).	Requires audited justification on disposition.
audit_logs	Append-only audit trail recording every case review, policy adjustment, and trust level change.	SHA-256 Hash Chain: Hash_N = SHA256(Hash_{N-1} Action Payload).
external_signals	PRAHARAK ingress telemetry: source IP, protocol, payload hash, signature validity, disposition.	Cryptographically hash-chained audit string.
circuit_breakers	Sliding-window velocity counters per source IP, state (CLOSED/OPEN), quarantine expiration timestamps.	Automated rate-limiting state machine.
cross_incidents	Unified hybrid incidents fusing external_signal_id + internal_event_id + case_id.	Binds outer probe to inner identity.

7. Unified REST API Endpoints & Contract

All backend capabilities are exposed over standard JSON REST APIs mounted at /api/v1:

METHOD & ROUTE	SUBSYSTEM	PURPOSE & RETURN CODES
POST /auth/login	Authentication	Authenticates demo credentials (analyst_sarah / admin_vikram); returns JWT bearer token.
POST /events	NIRIKSHAK	Ingests internal telemetry event, runs 7-layer scoring, auto-creates case if HIGH/CRITICAL.
GET /events/{id}/explanation	NIRIKSHAK	Returns mathematical factor attribution matrix showing exact point contributions.
POST /cases/{id}/review	Case Workflow	Applies human triage (DISMISS or ESCALATE) with mandatory audit justification string.
GET PUT /policies/{key}	Policy Engine	Queries or updates active dimensional risk weights and decision threshold boundaries.
PATCH /devices/{id}/trust	Device Trust	Updates device trust posture (TRUSTED, MONITORED, REVOKED) with audit entry.
POST /praharak/signals	PRAHARAK	Ingests external perimeter signal, verifies cryptographic envelope, outputs disposition.
GET /praharak/circuit-breaker	PRAHARAK	Returns real-time token-bucket velocity counters and quarantine status per source IP.
POST /praharak/circuit-breaker/reset	PRAHARAK	Manually lifts quarantine and resets counters for a specific external source IP.
GET /praharak/incidents	The Nexus	Lists cross-domain incidents correlated across the 30-minute sliding window.
POST /scenarios/trigger	Demo Harness	Triggers 4 NIRIKSHAK demo scenarios (normal, off_hours, exfiltration, kill_chain).
POST /praharak/scenarios/trigger	Demo Harness	Triggers 4 PRAHARAK demo scenarios (normal_telemetry, spoofed_command, ddos_flood, hybrid).

8. Frontend Dashboard & Analyst Command Console

The user interface combines a high-density **Modern SOC Dashboard** with an embedded **Analyst Command Console**:

Primary Framework Switcher	Prominent top-level toggle allows instant 1-click switching between NIRIKSHAK (Insider Risk) and PRAHARAK (Perimeter Defense) views, automatically synchronizing scenario demo buttons and telemetry streams.
----------------------------	---

Dynamic Scenario Controller	Displays 4 contextual scenario triggers tailored to the active system twin (4 insider scenarios vs 4 perimeter threat scenarios).
Cross-Domain Nexus Alert	High-priority animated alert card that surfaces unified hybrid incidents, displaying correlated external IP and internal employee identity.
Recharts Velocity Charts	Real-time temporal risk trajectory graphs with horizontal decision threshold lines (LOW, MODERATE, HIGH, CRITICAL).
Analyst Command Console	Docked keyboard drawer toggled via Ctrl + ~ (minimized by default for full screen visibility). Strictly built on a client-side AST allowlist parser that rejects operating system shell breakouts (sh, bash, sudo, rm, curl). Communicates over the exact same authenticated REST endpoints.

Allowlisted Terminal Command Grammar:

- status: Query system health, database state, Isolation Forest engine, and active risk scoring weights.
- events [limit]: Print ASCII tabular access telemetry feed with risk scores and decision tiers.
- cases: List open security cases pending human adjudication.
- investigate <case_id>: Display deep-dive case dossier, user history, and attributed factors.
- explain <event_id>: Output multi-factor mathematical risk attribution matrix.
- praharak status: Check perimeter telemetry volume, blocked counts, and tripped circuit breakers.
- praharak signals [n]: Inspect recent external signals, protocols, and dispositions.
- praharak circuit: View 10s fast / 60s sustained velocity counters and quarantine timestamps.
- praharak reset <ip>: Manually de-quarantine and reset circuit breaker counters.
- praharak incidents: List cross-domain correlation incidents linking external IPs to internal identities.
- praharak trigger <scenario>: Inject perimeter threat scenario directly from the command line.

9. The 8 Live Demonstration Scenarios

The system ships with 8 pre-seeded, on-demand demonstration scenarios ready for live evaluation:

SCENARIO & TWIN	SIMULATED THREAT PATTERN	RISK SCORE & SYSTEM DISPOSITION
1. Normal Access (NIRIKSHAK)	USER-001 reads Operational Repo A from enrolled laptop during standard working hours with MFA.	21.7 (LOW) → Logged & monitored in background. No case created.
2. Off-Hours Access (NIRIKSHAK)	USER-002 (Finance) reads Operational Repo A at 02:30 AM without MFA.	68.8 (HIGH) → Case automatically generated for analyst review.
3. Bulk Exfiltration (NIRIKSHAK)	USER-003 downloads 2.5 GB from unregistered DEV-999 at 03:15 AM.	88.5 (CRITICAL) → Immediate high-priority incident dossier created.
4. Multi-Stage Kill Chain (NIRIKSHAK)	Recon → Lateral repository enumeration → Privilege bypass → 1.8 GB Exfiltration within 15 mins.	93.9 (CRITICAL) → Sliding-window multiplier (1.35x) escalates incident.
5. Normal Beacon (PRAHARAK)	Legitimate edge gateway sends signed HTTPS telemetry with valid HMAC-SHA256 and fresh nonce.	12.5 (LOW) → Cryptographically verified. ALLOWED.
6. Spoofed Command (PRAHARAK)	Forged drone reroute command submitted with invalid Ed25519 cryptographic signature.	92.5 (CRITICAL) → Zero-trust rejection before execution. BLOCKED.
7. DDoS Flood (PRAHARAK)	Adversary floods gateway with 17 rapid burst requests within 3 seconds.	85.0 (CRITICAL) → Token-bucket trips to OPEN. 15m QUARANTINE.
8. Hybrid Nexus Attack (CROSS-DOMAIN)	External brute-force probe from 198.51.100.77 correlated with internal credential exfiltration by USER-004.	100.0 (CRITICAL) → Unified Cross-Domain Nexus Alert linking IP to Identity.

10. Automated Verification & Security Hardening

NIRIKSHAK and PRAHARAK enforce strict Definition of Done (DoD) compliance with 100% automated regression coverage:

TEST SUITE MODULE	VERIFIED SCOPE & SECURITY BOUNDARIES	STATUS
test_foundation.py	Schema generation, PostgreSQL seed fixtures, JWT authentication & password hashing.	PASSED (2/2)

test_risk_engine.py	Deterministic factor calculation, score normalization, boundary capping (0-100), weight validation.	PASSED (4/4)
test_ml_and_correlation.py	6D feature extraction, Isolation Forest inference, temporal sliding windows, kill-chain multiplier.	PASSED (3/3)
test_ingestion_and_scenarios.py	REST telemetry ingestion, scenario injection, automated case opening for scores ≥ 61.0 .	PASSED (2/2)
test_case_management_and_audit.py	Case review lifecycle (DISMISS/ESCALATE), justification requirement, SHA-256 audit chaining.	PASSED (1/1)
test_policies_and_devices.py	Dynamic scoring weight adjustments, threshold tuning, device trust lifecycle (TRUSTED/REVOKED).	PASSED (2/2)
test_praharak.py	Cryptographic anti-spoofing, token-bucket circuit breaker state machine, MITRE recon, Nexus fusion.	PASSED (7/7)
test_security_boundaries.py	SQL injection resistance, AST allowlist parser command injection rejection, audit log immutability.	PASSED (4/4)

11. 5-Minute 4-Person Hackathon Presentation Script

Structured speaker breakdown for live hackathon demonstration:

TIME / SPEAKER	KEY MESSAGE & CORE CONCEPTS	LIVE SCREEN ACTION
0:00 - 1:00 Lead / Backend	State the Problem Statement & Foundational Axiom (Unusual $\neq$ Malicious). Introduce NIRIKSHAK & PRAHARAK as the 360-degree dual-twin cyber defense prototype.	Showcase Dual-Twin header and live system health badge (Postgres: Online).
1:00 - 2:15 Detection / ML	Demonstrate deterministic scoring + Isolation Forest anomaly detection. Explain that NIRIKSHAK never uses black-box scores—it outputs transparent mathematical attributions.	Click Scenario 1: Normal (Score: 21.7), then click Scenario 2: Off-Hours (Score: 68.8) and open Factor Inspector.
2:15 - 3:30 DevOps / Sim	Demonstrate multi-stage attack progression. Explain how sliding temporal windows correlate multi-event bursts and apply sequential APT multipliers to generate a security case.	Click Scenario 4: Kill Chain . Point to Recharts temporal velocity wave and automated case creation.
3:30 - 5:00 Frontend / Sec	Introduce PRAHARAK (Perimeter Twin). Trigger Hybrid Coordinated Attack. Showcase Cross-Domain Correlation fusing external IP with internal identity. Demonstrate terminal (Ctrl + ~).	Switch to PRAHARAK . Click Hybrid Attack . Show Nexus Alert. Open terminal (Ctrl + ~), type praharak incidents.

CONCLUSION: NIRIKSHAK and PRAHARAK demonstrate that cybersecurity decision support can be fully contextual, cryptographically verifiable, and human-supervised without succumbing to black-box alert fatigue or unexplainable autonomous actions. The codebase is production-ready, fully tested, and containerized for deployment.

Document compiled automatically from repository source code, passing test runs, and system models. All entities are 100% synthetic.